

REPORT DI ANALISI MALWARE

Esercizio 2 – Studio IoC | Cyber Security & Ethical Hacking

Campo	Dettaglio
Sample URL	https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe
Task ID	9a158718-43fe-45ce-85b3-66203dbc2281
Data Analisi	25 Agosto 2024, 20:38:59 UTC
Piattaforma	ANY.RUN Interactive Sandbox
OS Target	Windows 10 Professional (build 19045, 64-bit)
Verdetto	MALICIOUS ACTIVITY
MD5	00B5E91B42712471CDFBDB37B715670C
SHA1	D9550361E5205DB1D2DF9D02CC7E30503B8EC3A2
SHA256	0307EE805DF8B94733598D5C3D62B28678EAEADB1CA3689FA678A3780DD3DF0
Tag	github, netreactor

1. Sommario Esecutivo

L'analisi dinamica condotta su ANY.RUN ha rilevato un campione di malware distribuito tramite GitHub, classificato come attività malevola con verdetto MALICIOUS. Il file eseguibile Jvczfhe.exe è un dropper .NET offuscato con .NET Reactor (tool di protezione del codice), progettato per eseguire un payload iniettato in memoria mediante la tecnica di Process Hollowing, sfruttando il processo legittimo InstallUtil.exe come vettore di esecuzione furtiva.

Il campione implementa un meccanismo di persistenza, comunica con infrastrutture di Command & Control (C2) tramite DNS dinamico (DuckDNS), e adotta molteplici tecniche di evasione dei sistemi di difesa. Il comportamento complessivo è coerente con quello di un info-stealer o RAT (.NET-based) della famiglia Snake Keylogger / Agent Tesla o varianti affini.

2. Vettore di Infezione e Distribuzione

2.1 GitHub come piattaforma di hosting

Il campione è stato distribuito tramite un repository GitHub pubblico (account: MELITERRER, repo: frew). Questo vettore è sempre più comune tra gli attori malevoli perché consente di:

- Bypassare i blocchi basati su reputazione IP (GitHub è un dominio trusted)
- Sfruttare CDN affidabili per garantire alta disponibilità del payload
- Oscurare la vera identità dell'infrastruttura C2
- Aggiornare il payload in tempo reale senza modificare gli IOC primari

La richiesta iniziale parte da Firefox (PID 6552/6596) verso github.com (IP: 140.82.121.3:443), confermando il download del campione tramite connessione HTTPS cifrata.

2.2 Offuscamento con .NET Reactor

.NET Reactor è un tool legittimo di protezione del codice .NET, tuttavia viene sistematicamente abusato da sviluppatori di malware per:

- Offuscare il codice sorgente e impedire il reverse engineering statico
- Cifrare i metadati dell'assembly .NET
- Generare nomi casuali per metodi e variabili (es. il file stesso: Jvczfhe.exe, Muadnrd.exe)
- Rallentare l'analisi automatizzata dei motori antivirus

3. Catena di Infezione (Kill Chain)

Di seguito la sequenza di esecuzione ricostruita dall'analisi comportamentale:

FASE 1 – Dropper: Jvczfhe.exe (PID 7492) viene eseguito. Avvia cmd.exe e usa TIMEOUT.EXE per ritardare l'esecuzione (tecnica anti-sandbox).

FASE 2 – Process Hollowing: Jvczfhe.exe spawn InstallUtil.exe (PID 5152) — un processo legittimo Microsoft .NET Framework — in modalità sospesa, ne svuota la memoria e vi inietta il payload malevolo. InstallUtil viene quindi ripreso e il codice malevolo esegue nel contesto di un processo trusted.

FASE 3 – Persistenza: Muadnrd.exe (PID 7824) viene lanciato come copia del dropper, eseguendo un secondo ciclo di process hollowing (Muadnrd.exe PID 7248). Il malware si rilancia autonomamente (Application launched itself).

FASE 4 – C2 Communication: InstallUtil.exe si connette su una porta non standard (unusual port) verso un dominio DuckDNS. Vengono rilevate 19 network threat alert da parte del motore IDS integrato in ANY.RUN.

4. Tecniche di Evasione Identificate

Il campione implementa un arsenale sofisticato di tecniche anti-detection e anti-analysis:

- Process Hollowing (T1055.012): Iniezione del payload nel processo legittimo InstallUtil.exe per mascherare l'esecuzione malevola
- Execution Delay via TIMEOUT.EXE (T1497): Ritardo artificiosa dell'esecuzione per eludere sandbox con timeout brevi
- Uso di LOLBin (T1218.004): InstallUtil.exe è un binario Microsoft firmato (Living-off-the-Land Binary), il cui uso anomalo è difficile da rilevare
- Dynamic DNS per C2 (T1568): Uso di DuckDNS per nascondere l'IP reale del server C2, che può cambiare dinamicamente
- Disabilitazione Trace Logs: Jvczfhe.exe e Muadnrd.exe disabilitano i log di tracciamento di sistema
- Controllo delle impostazioni di Trust di Windows: Il malware verifica le Trust Settings per adattare il comportamento all'ambiente
- Lettura delle impostazioni di sicurezza di Internet Explorer: Tecnica usata per rilevare la presenza di proxy o ambienti sandbox
- Lettura del Computer Name e Machine GUID: Fingerprinting dell'host vittima per generare un ID univoco
- Controllo delle lingue supportate: Possibile evasione geografica (es. non infetta sistemi con lingua russa/CIS)

5. Analisi del Traffico di Rete

5.1 Connessioni e Minacce IDS

Il motore IDS di ANY.RUN ha rilevato 19 alert di rete. Le principali categorie:

- 'ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain' (Potentially Bad Traffic): Query DNS verso dominio DuckDNS, tipico pattern dei malware che usano DDNS per il C2
- 'INFO [ANY.RUN] Attempting to access raw user content on GitHub': Tre richieste al raw content di GitHub, coerenti con il download del payload
- Connessione su porta non standard da InstallUtil.exe: Fortemente indicativa di comunicazione C2 attiva

5.2 Statistiche di Rete

- Richieste HTTP(S): 31 totali
- Connessioni TCP/UDP: 99 totali

- Query DNS: 161 totali
- Alert minacce: 19 rilevati

6. Mappatura MITRE ATT&CK

Tecnica	ID ATT&CK	Evidenza nel Sample
Spearphishing via GitHub	T1566 / T1204	File scaricato da repository GitHub pubblico
Process Hollowing	T1055.012	Payload iniettato in InstallUtil.exe (PID 5152)
LOLBin - InstallUtil	T1218.004	InstallUtil.exe usato come host del payload
Execution Delay	T1497.003	TIMEOUT.EXE usato per ritardare l'esecuzione
Dynamic DNS Resolution	T1568	DuckDNS per comunicazione C2 resiliente
System Information Discovery	T1082	Lettura Computer Name, GUID, lingua, OS
Disabilitazione Logging	T1562.006	Trace logs disabilitati da entrambi i dropper
Execution via Cmd	T1059.003	Avvio di cmd.exe per operazioni di sistema
File Drop - Eseguibile	T1105	Secondo eseguibile (Muadnrd.exe) droppato e avviato

7. Indicatori di Compromissione (IoC)

Tipo	Valore	Descrizione
Hash MD5	00B5E91B42712471CDFBDB37B715670C	Hash del campione principale (Jvczfhe.exe)
Hash SHA256	0307EE805DF8B94733598D5C3D62B...3DF0	SHA256 del campione principale
Filename	Jvczfhe.exe	Nome del dropper principale (offuscato)
Filename	Muadnrd.exe	Seconda istanza del dropper (persistenza)
URL	github.com/MELITERRER/frew/	URL di distribuzione del payload su GitHub

Processo	InstallUtil.exe	Processo legittimo usato per Process Hollowing
DNS Pattern	*.duckdns.org	Pattern del dominio C2 (Dynamic DNS)
Porta	Porta non standard	Porta anomala usata da InstallUtil.exe per C2
Tecnica	cmd.exe + TIMEOUT.EXE	Catena di esecuzione per delay anti-sandbox
Protettore	.NET Reactor	Tool usato per offuscare il codice .NET

8. Valutazione del Rischio e Raccomandazioni

8.1 Livello di Rischio: ALTO

Il campione mostra caratteristiche tipiche di un info-stealer / RAT avanzato con capacità di:

- Esecuzione furtiva in processi legittimi (elude la maggior parte degli AV tradizionali)
- Comunicazione C2 resiliente tramite DDNS (difficile da bloccare con blacklist statiche)
- Raccolta di informazioni di sistema (base per fingerprinting e targeting avanzato)
- Persistenza mediante rilancio automatico del processo

8.2 Raccomandazioni Difensive

- Monitorare e bloccare l'esecuzione anomala di InstallUtil.exe (spawn senza argomenti, connessioni di rete insolite)
- Implementare regole YARA/Sigma per rilevare Process Hollowing su LOLBin .NET
- Bloccare il traffico verso domini *.duckdns.org a livello firewall/DNS filtering (a meno di usi aziendali legittimi documentati)
- Configurare EDR per rilevare la catena: eseguibile sconosciuto -> cmd.exe -> timeout.exe -> InstallUtil.exe
- Abilitare PowerShell ScriptBlock Logging e Process Creation Logging (Windows Event ID 4688)
- Applicare application whitelisting per impedire l'esecuzione di binari non autorizzati
- Verificare regole firewall outbound per bloccare connessioni su porte non standard da processi di sistema
- Adottare sandboxing automatico di tutti i file scaricati da internet prima dell'esecuzione

9. Conclusioni

Il campione analizzato rappresenta un esempio ben strutturato di malware .NET moderno che combina tecniche di offuscamento, evasione e injection avanzate. La distribuzione tramite

GitHub e l'uso di DuckDNS per il C2 sono pattern ricorrenti nelle campagne di info-stealing e RAT distribution del 2023-2024.

Dal punto di vista didattico, questo caso illustra perfettamente perché la sola firma antivirus non è sufficiente: il payload opera all'interno di un processo firmato Microsoft (InstallUtil.exe), il traffico di rete si mescola a quello legittimo (GitHub HTTPS), e i meccanismi di ritardo eludono le sandbox con timeout brevi. Una difesa efficace richiede approcci comportamentali, EDR evoluti e threat hunting proattivo.

Report redatto ai fini didattici | Corso Cyber Security & Ethical Hacking | EPICODE | 20 Febbraio 2026